

SecPlatform Horizon

Where enterprise vulnerability management went between 2019 and 2026, what the winners and the dead teach, and a staged roadmap for SecPlatform — vulnerability management and penetration-test support included.

Compiled from an 11-segment parallel research sweep (Tenable • Qualys • Rapid7 • aggregation platforms • pentest management • PTaaS • prioritization science • market trends • open source • financial-sector regulation • vulnerability-data supply chain), ~40 primary sources, cross-checked against SecPlatform's verified current state. 21 raw proposals were de-duplicated and feasibility-screened to 17.

01 The market in three acts

2019 – 2022

From severity to risk scores

Every incumbent concluded that CVSS alone drowns teams, and shipped a threat-aware score on top: Tenable **VPR** (2019), Qualys **VMDR/TruRisk** (2020–22), Rapid7 **Active Risk** (2023). Under the marketing, all three compute the same thing: *technical impact* × *exploitation likelihood* × *asset criticality* — and the likelihood inputs are largely free public feeds (EPSS, CISA KEV, Metasploit/ExploitDB existence, ransomware association). Qualys went furthest by publishing the exact formula, weights and caps; that transparency, not the score itself, is what auditors and skeptical engineers reward.

2022 – 2025

From scanners to exposure platforms

Gartner coined **CTEM** (scope → discover → prioritize → validate → mobilize) in 2022 and by November 2025 had a formal market — the first Exposure Assessment Platforms Magic Quadrant, with Tenable, Qualys and Rapid7 as Leaders. The defining move: every leader bought a *scanner-agnostic aggregation layer* because their own sensors weren't enough. Six independent aggregators exited at \$150–450M in four years — Kenna, RiskSense, Avalor, Silk, Dazz, and Vulcan Cyber, whose engine became Tenable One's

third-party ingestion. The middle layer — ingest everyone's findings, dedupe, add business context, route to owners, track SLAs — proved to be the most valuable real estate in the category. **That layer is the shape SecPlatform already has.**

2025 - 2026

Validation, AI — and a fracturing data supply chain

The frontier moved to *proof*: adversarial exposure validation (XBOW, Horizon3 — \$200M+ raised each) and narrow, human-gated AI that survived buyer skepticism — Tenable's genAI-rebuilt VPR tags CVEs from unstructured threat text; natural-language querying became table stakes. Meanwhile the public data layer cracked: NIST formally abandoned universal NVD enrichment (April 2026, only ~15–20% of CVEs now enriched), the CVE program had a 17-hour funding near-death (April 2025), and the EU stood up its own EUVD identifiers under NIS2. Skybox — 20+ years of legacy VM, no platform story — shut down in a single day in February 2025.

02 Seven lessons the market already paid for

L1 Publish the score math

Documented, deterministic formulas (TruRisk's explicit weights; VPR's named drivers) beat black-box "AI risk scores" with auditors and engineers alike. Every vendor that ships multiple scores now ships the one-page explainer with them.

precedent: Qualys TruRisk formula docs • Tenable "Scoring Explained"

L2 KEV is a floor, EPSS is a probability, CVSS is impact

The operational consensus across all three leaders: KEV membership auto-escalates to fix-now; EPSS is a daily-refreshed likelihood with thresholds, never frozen into a composite; CVSS supplies impact context. All three signals are free. CISA's BOD 26-04 (June 2026) is now writing this logic into regulation as risk-tiered deadlines.

precedent: Active Risk • QVS • VPR — all blend exactly these • BOD 26-04

L3 The remediation-centric inversion

Rapid7's Remediation Hub flipped the model: group findings by *fix*, rank fixes by aggregate risk reduction, show "apply these 25 → X findings closed on Y assets." A sorted vulnerability list is what engineers scroll; a ranked fix list is what they act on.

DefectDojo learned the same lesson from below: one-Jira-ticket-per-finding destroys developer trust — group before you push.

precedent: Rapid7 Remediation Hub · DefectDojo finding groups (PR #4017)

L4 Findings are structured objects, reports are exports

PTaaS's lasting change: a finding is a state machine with an owner, severity, comment thread, evidence and a retest history — consumed in the developer's backlog during the test, not read in a PDF weeks after. The compliance PDF survived, demoted to a generated artifact. Retest became a per-finding button with a ~72-hour norm, not a renegotiated engagement.

precedent: HackerOne Triage→Retesting→Resolved · Cobalt bi-directional Jira (2020)

L5 Reimport reconciliation is the actual hard problem

DefectDojo's decade of production issues is the honest record: one global dedup algorithm cannot work (per-scanner field configuration is permanent curation), dedup should scope to one asset by default, and the valuable API is not "import findings" but "reconcile this scan against existing triage state" — close absent, reopen reappearing, or let the platform stay authoritative. Commercial "smart correlation" marketing is this feature.

precedent: DefectDojo dedup algorithms · reimport-scan flags · FP fingerprint history

L6 Exceptions must decay

ServiceNow's exception management — risk acceptance behind multi-level approval, *expiring by default*, auto-reactivating the finding at expiry — is what auditors now expect. PCI DSS 12.3.1 and NIS2-style rules fail a silent, undated "accept risk" checkbox.

precedent: ServiceNow VR exception mgmt · PCI DSS 4.0 §12.3.1

L7 Ship narrow AI with a human gate; discount everything else

The AI features that earned trust are bounded: pipeline enrichment (tagging CVEs from unstructured threat text — Tenable's highest-ROI genAI use and explicitly cheap to replicate), triage assistance with published accuracy, writeup QA. Buyers now openly discount announcement-stage "agentic fabrics." Validation is being commoditized by specialists — integrate it as a signal, never build it.

precedent: VPR genAI rebuild (Jul 2025) · AttackForge writeup AI · XBOW/Horizon3

DATA SUPPLY CHAIN

Plan for a world where **NVD enriches only ~15–20% of CVEs** and identifiers are plural (CVE, EUVD, GCVE). Concretely: keep an internal surrogate key with an ID crosswalk, store per-attribute source and timestamp, and build an enrichment waterfall — CNA-supplied data → CISA Vulnrichment → free backfill (VulnCheck NVD++) — rather than gating anything on an NVD score appearing. Exploited-list coverage should be a union (CISA KEV + VulnCheck KEV + EUVD), not CISA alone: ~29% of 2025's exploited CVEs were exploited on or before publication.

REGULATORY WEATHER

EU rules now specify what a bank's VM platform must *do*: DORA's RTS mandates weekly scanning of critical-function assets, recorded resolution of every vulnerability, deadline escalation trails, and board-level reporting (Art. 5 makes management personally accountable); TLPT is a multi-quarter evidence pipeline, not a pentest with a retest button. **DORA does not bind a Vietnamese bank** — but it is the direction of regulatory travel, correspondent-banking expectations increasingly reference it, and its concrete patterns (asset-to-critical-function mapping, two-clock SLAs, evidence-pack exports, a management-body reporting view) are worth adopting on merit. SBV alignment should be checked by compliance; the mechanics transfer.

03 Where SecPlatform stands

SecPlatform is not a scanner and should never become one. Its shape — standardized asset inventory with business context, findings lifecycle with enforced workflow and SLA states, Jira intake with AI triage, governed risk acceptance, full audit — is precisely the *aggregation-and-orchestration middle layer* that six companies rode to \$150–450M exits. The market validated the category; what SecPlatform lacks is depth in three places the research makes measurable:

ALREADY STRONG

- Asset inventory with criticality, exposure, aliases, BU scoping

MEASURABLE GAPS

- Intake is Jira-only — no scanner/SARIF/CSV ingestion, no dedup

- Enforced finding lifecycle, SLA states, saved views
- Two-person risk acceptance, fail-closed audit
- AI ticket triage with human review gates
- Bilingual EN/VI throughout

- CVE/CVSS fields exist but nothing consumes them — severity-only triage
- PENTEST is a label, not a capability — no scope, evidence, retest, report
- No trend view over the snapshots it already collects
- Known backlog: notifications ungenerated, SLA outcome not finalized, acceptances never expire

04 The roadmap

Seventeen proposals, staged so each phase compounds the last. Ordering follows the market's own dependency chain: integrity first (trustworthy numbers), then intake (become the system of record), then pentest depth, then posture and AI. Effort: S = days, M = 1–3 weeks, L = 1–2 months for a small team.

1 Integrity & quick wins

make existing numbers trustworthy

Remediation-integrity bundle

S-M

IMPACT HIGH

One contained change to the hourly SLA worker closes three known gaps: freeze MET/MISSED + days-to-remediate at closure (backfill from status history); make risk-acceptance expiry real — required expiry date, auto-reactivation into the open workflow, re-approval through the existing two-person gate; and wire the first notification producers (pre-breach, post-breach, assignment, expiry) into events that already fire. Without this, every compliance number the platform reports is unreliable.

precedent: Brinqa five-state SLA model • ServiceNow exception expiry • DefectDojo SLA_NOTIFY windows

Finding writeup library

S

IMPACT HIGH

Reusable finding templates (title, description, recommendation, CWE, baseline CVSS — EN and VI) with a picker that prefills the finding form and a "save as template" on any existing finding. Writeup reuse is where testers save the most hours; PlexTrac's 25,000-writeup library is the segment's acknowledged moat.

precedent: PlexTrac WriteupsDB • Dradis IssueLibrary • DefectDojo templates

Anti-roadmap ADR

S

IMPACT HIGH

Record the five non-goals below as an architecture decision so every vendor announcement doesn't reopen the debate.

2 System of record

intake · enrichment · priority

SARIF + generic CSV finding intake M IMPACT HIGH

A FindingImport module mirroring the existing Excel asset-import pattern (upload → parse → reconciliation preview → commit): SARIF 2.1.0 covers CodeQL, Semgrep, Trivy and most modern scanners for free; a CSV/JSON adapter with saved per-source column mappings covers consultancy spreadsheets and the long tail. Findings route through the existing alias-based application matcher. Fingerprint findings *from day one* (per-source field sets, scoped to one application) even before reimport semantics land.

precedent: OASIS SARIF · Nucleus FlexConnect · DefectDojo generic import

Reimport reconciliation engine L IMPACT HIGH

The second import of the same source must reconcile, not duplicate: absent-from-new-report auto-mitigates (optional), reappearing findings reopen through the enforced workflow, a do-not-reactivate flag keeps SecPlatform's triage authoritative, and false-positive/risk-accepted status survives rescans via fingerprint memory. This is the genuinely hard feature — DefectDojo's multi-year bug tail says budget for edge cases, which is why it's staged after intake ships.

precedent: DefectDojo reimport-scan semantics + FP fingerprint history

Threat-intel enrichment waterfall M IMPACT HIGH

A nightly worker joins free feeds to the CVE IDs the platform already stores: CISA KEV (membership, ransomware flag), EPSS daily scores (probability + percentile, never frozen), CISA Vulnrichment SSVC stubs, optional VulnCheck backfill — with per-attribute source provenance and an ID-crosswalk design (CVE/EUVD) from the start. KEV becomes a hard override lane: badge, auto-escalated due date, a "Known Exploited" saved view beside the existing Breached-SLA deep link.

precedent: the exact free-feed blend inside VPR, QVS and Active Risk · NVD-collapse mitigation per CISA Vulnrichment

Published priority score with Act / Attend / Track lanes M IMPACT HIGH

A deterministic 0–1000 score — CVSS impact × exploitation likelihood (EPSS band, KEV, ransomware) × business context the platform already owns (criticality, internet exposure, mirroring Qualys' +20% internet-facing uplift) — shipped *with its one-page formula* and per-finding driver breakdown. The score maps to SSVC-style decision lanes (Act / Attend / Track) that bind to SLA tiers; per-application roll-up feeds the inventory and executive views. This is where SecPlatform stops sorting by severity label.

precedent: TruRisk published formulas · VPR/ACR layering · SSVC / BOD 26-04 decision logic

Fix-owner routing rules M IMPACT MED

Deterministic first: an AssignmentRule table (application, BU, source, severity, component → default owner) seeded from existing ApplicationOwner records, evaluated at creation and import. The ML/LLM suggestion layer the market sells ("Find the Fixer") is optional later — through the existing human-review queue, never auto-assigning.

precedent: ServiceNow CI-lookup + assignment rules · Seemplicity Find-the-Fixer (deferred)

3 Real pentest support

engagement · evidence · retest · report

Pentest engagement layer M IMPACT HIGH

A PentestEngagement extension on the existing Assessment: scope items, test window, approach, rules of engagement, tester roster, scope freeze — plus a pentest workflow seeded into the existing engine (Requested → Scoped → Testing → Reporting → Retest → Closed). Findings stay ordinary Vulnerability rows linked to the engagement; no parallel model.

precedent: DefectDojo Engagement container · AttackForge project-request workflow

Evidence attachments with access control M IMPACT HIGH

A polymorphic Attachment model (screenshots, request/response captures, PoC files) on MinIO next to the existing stack — the one new infrastructure dependency in this roadmap. Downloads go through RBAC + BU scoping with audit entries: evidence is exploit material inside a bank, so access is fail-closed like other critical actions.

precedent: AttackForge evidence archives · PTaaS structured-finding norm

Per-finding retest workflow M IMPACT HIGH

A RetestRequest model and a RETESTING workflow status: fix owner requests → tester claims → FIXED sets the currently-orphaned verifiedDate, drives closure and finalizes the SLA outcome; STILL_VULNERABLE reopens with failure evidence attached. Engagement-wide "retest all open" reuses the bulk-action pattern. PTaaS made this a per-finding button with a 72-hour norm — it is now a baseline buyer expectation.

precedent: HackerOne retest state machine · AttackForge bulk retest

Versioned methodology checklists M IMPACT MED

Import public frameworks (OWASP WSTG, CIS subsets) as versioned checklist templates; attaching one to an engagement snapshots items with per-item state and a one-click "raise finding." Coverage percent becomes the QA gate before Reporting — and the evidence internal audit asks for.

precedent: PlexTrac Runbooks · AttackForge framework imports with dated versions

DOCX report generation M IMPACT HIGH

Serialize an engagement to canonical JSON and merge into bank-branded DOCX templates (EN + VI) in a worker; store each generated report as a versioned, audited attachment. The standalone JSON export lets the team adapt its existing Word templates. Consultancies live in Word — this is the segment's cheapest adoption wedge.

precedent: AttackForge ReportGen · Dradis/Hexway DOCX pipelines

AI writeup review gate S IMPACT MED

A pre-report pass through the existing AI gateway: completeness, severity-vs-impact consistency, CWE suggestions — advisory badges only, deterministic fallback when AI is off, matching the platform's established human-in-control pattern.

precedent: AttackForge writeup AI (2025) · PlexTrac Plex AI

4 Posture & AI depth

trend · tagging · fix-centric view

Posture trend view M IMPACT HIGH

A read layer over the DailySnapshot table the platform already populates nightly: severity trends, SLA compliance rate, MTTR, internet-exposed critical exposure — org and per-BU, with drill-down into existing saved views and a management-reporting export. This is the board-level artifact regulation is converging on, and it needs Phase 1's SLA finalization to be truthful.

precedent: Tenable Lumin trending · InsightVM live SLA goal cards · DORA Art. 5 board accountability

GenAI threat tagging + cached summaries M IMPACT MED

A second AI pass in the existing triage worker: tag findings from unstructured text (exploited-in-wild, PoC-public, ransomware-associated) feeding the priority score's likelihood axis, plus cached per-finding threat summaries regenerated only when inputs change. Low-confidence tags queue for human review, reusing the alias-learning guard discipline.

precedent: Tenable's genAI-rebuilt VPR — explicitly "cheap to replicate"

Fix-centric remediation grouping M IMPACT MED

Group open findings by application + CWE/component, rank groups by aggregate priority-score reduction ("this fix closes 14 findings, -2,340"), and push one grouped Jira ticket per fix through the existing writeback. Built only after the priority score exists — ranking by count alone isn't worth shipping.

precedent: Rapid7 Remediation Hub · DefectDojo finding groups

05 The anti-roadmap

Five things SecPlatform will **not** build in the next 12–24 months, each backed by a documented market failure or commoditization:

1. **No attack-path analysis or exposure graph.** It requires identity, cloud and network telemetry the platform will never ingest; partial graphs mislead more than they inform.
2. **No autonomous agents.** Only narrow, human-gated AI passes. Buyers now explicitly discount announcement-stage agentic fabrics; the credible shipped AI is bounded and measurable.
3. **No scanner and no exploit-validation engine.** XBOW and Horizon3 are commoditizing validation with \$200M+ each; if validation evidence ever matters, ingest it as a prioritization signal.
4. **No further NL-querying investment.** It is table stakes across every vendor; differentiation moved to enrichment quality and remediation execution.
5. **No rebrand, no score sprawl.** Tenable and Rapid7 burned years of buyer comprehension on renames; Qualys needed a decoder page for four scores. One name, one score, one published formula.

06 Sources

A selection of the ~40 primary sources consulted; full digests with per-segment source lists are retained in the research archive.

TENABLE

VPR vs CVSS — scoring drivers
Tenable One launch (2022)
2025 VPR genAI rebuild FAQ

QUALYS

TruRisk score formula (published weights)
TruRisk methodology

RAPID7

Active Risk introduction
Exposure Command launch

AGGREGATION LAYER

Nucleus Security platform
Nucleus on cross-source dedup

PENTEST MANAGEMENT

PlexTrac Runbooks
Cobalt: history of PTaaS

PRIORITIZATION

FIRST.org EPSS
EPSS v5 (2026)
State of VEX (2026)

OPEN SOURCE

DefectDojo dedup algorithms
DefectDojo data hierarchy

REGULATION

DORA RTS (CDR 2024/1774)
DORA TLPT RTS

DATA SUPPLY CHAIN

NIST narrows NVD enrichment (Apr 2026)

CVE program funding crisis

ENISA as EU CVE Root

Prepared for the ABBank SecOps team, September 2026. Method: 11 parallel research segments with structured digests, a coverage critic that added the regulatory and data-supply-chain segments, three proposal lenses grounded in SecPlatform's verified current state, and a feasibility screen that merged 21 raw proposals into the 17 above (two duplicate pairs merged; the SLA/notification/expiry trio consolidated). Claims about vendor internals reflect public documentation as of September 2026.